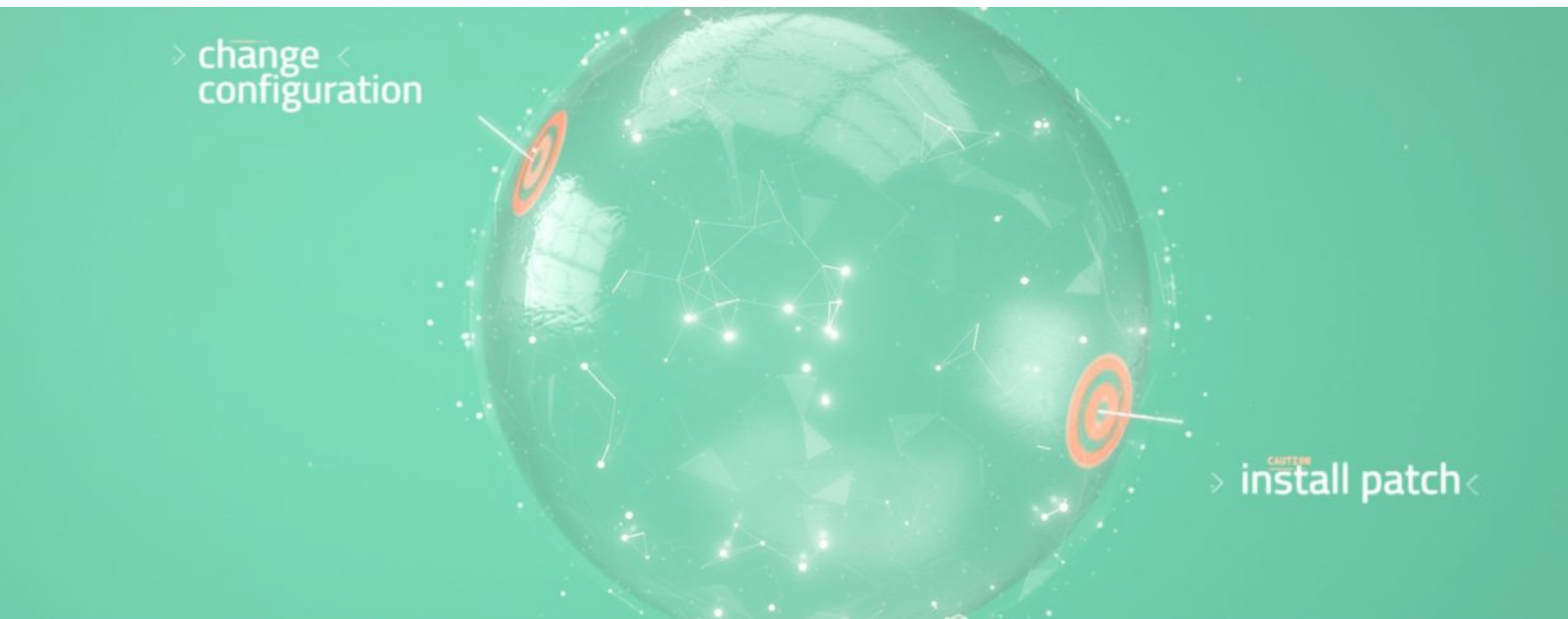


Executive Summary



Web Application Firewall

Cymulate Demo (Default Environment)

Web Applications have become a central business component in many organizations, and huge amounts of money and effort are spent protecting these assets. In the past IT security teams just had a few enterprise web apps to defend. Now they need to protect the web back-end of multiple and varied mobile apps, SaaS apps and other cloud-delivered solutions. The Web Application assessment will test your configuration, implementation, and abilities, ensuring the Web Application Firewall blocks common types of simulated malicious payloads before they get anywhere near your Web Application.

Could somebody send malicious requests to my web application?

Injection

XML External Entities

Cross-Site Scripting

Security Misconfiguration

Using Components with Known Vulnerabilities

Server Side Request Forgery

Assessment Summary

Cymulate Score

79/100

Penetration Ratio

63%

Your Web Application security exposure level is:

● High

Risk Summary

Score breakdown by risk level

!!!	High Risk	89%		8132/9103
!!	Medium Risk	58%		1757/3026
!	Low Risk	58%		31702/54625

Attack Type Summary

Score breakdown by attack types

	File Inclusion	58%		1757/3026
	SQL-Injection	83%		1921/2322
	XSS	58%		31165/53936
	SSRF	78%		537/689
	Command Injection	92%		6086/6600
	XML Injection	69%		125/181
	NoSQL injection	82%		246/299
	WAF Bypass	0%		0/0

Web Application Firewall Assessment Insights



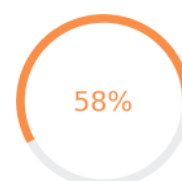
You are least protected from **Command Injection**

Crafted payloads that can lead to potential execution of arbitrary commands on the host operating system via a vulnerable application. Command injection attacks are possible when an application passes unsafe user supplied data (forms, cookies, HTTP headers etc.) to a system shell.



You are most protected from **XSS**

Crafted payloads that can potentially enables attackers to inject client-side scripts into web pages viewed by other users.



High Risk Inputs

Cymulate has detected 239 input fields on the site.
221 inputs are considered high risk due to their high penetration rate



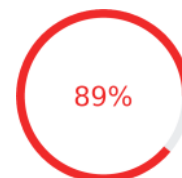
High Risk Forms

Cymulate has detected 32 form input fields on the site.
30 form input fields are considered high risk due to their high penetration rate



High Risk Payloads Ratio

High risk payloads are considered as such due to the extent of the influence they might have.
Sent payloads: 9103.
Detected: 8132



Least Protected Site

<http://app.cymulate.com>

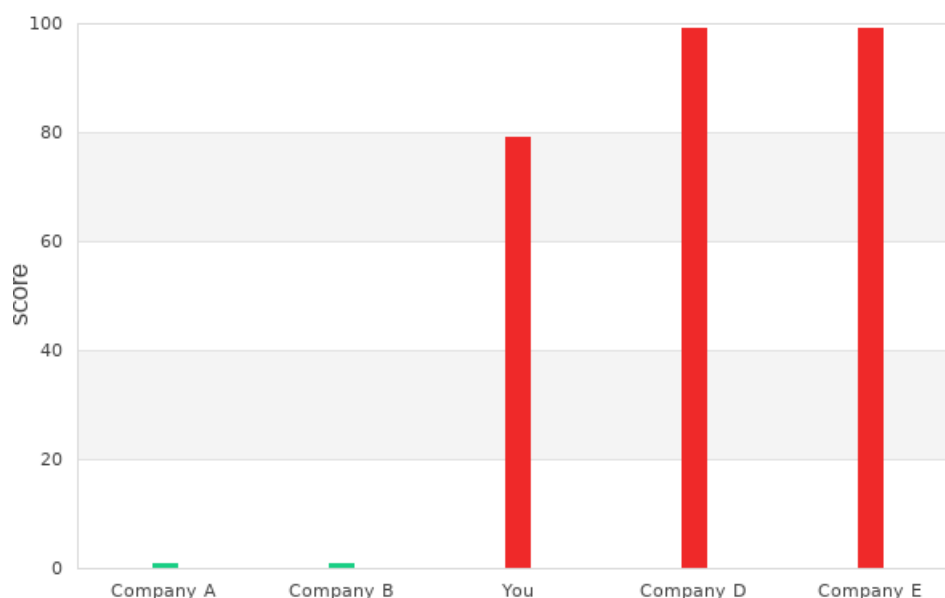
Benchmark - Financial Services

This graph represents your organization exposure score compared with other organizations (Company A, Company B, You, Company D, Company E) in your industry globally.

The average score in your industry is: 31

Your score is: 79

*Benchmark was calculated as of 16/06/2026



Performance

This graph represents your performance in each Attack Type over the last 10 assessments



Executive Action Items



Web Application Items

Cymulate detected that you can solve 62% of the score by re-configuring your WAF filters to block malicious requests to your web application (with no impact to your business). These mitigations can be achieved by creating different filters on your WAF:

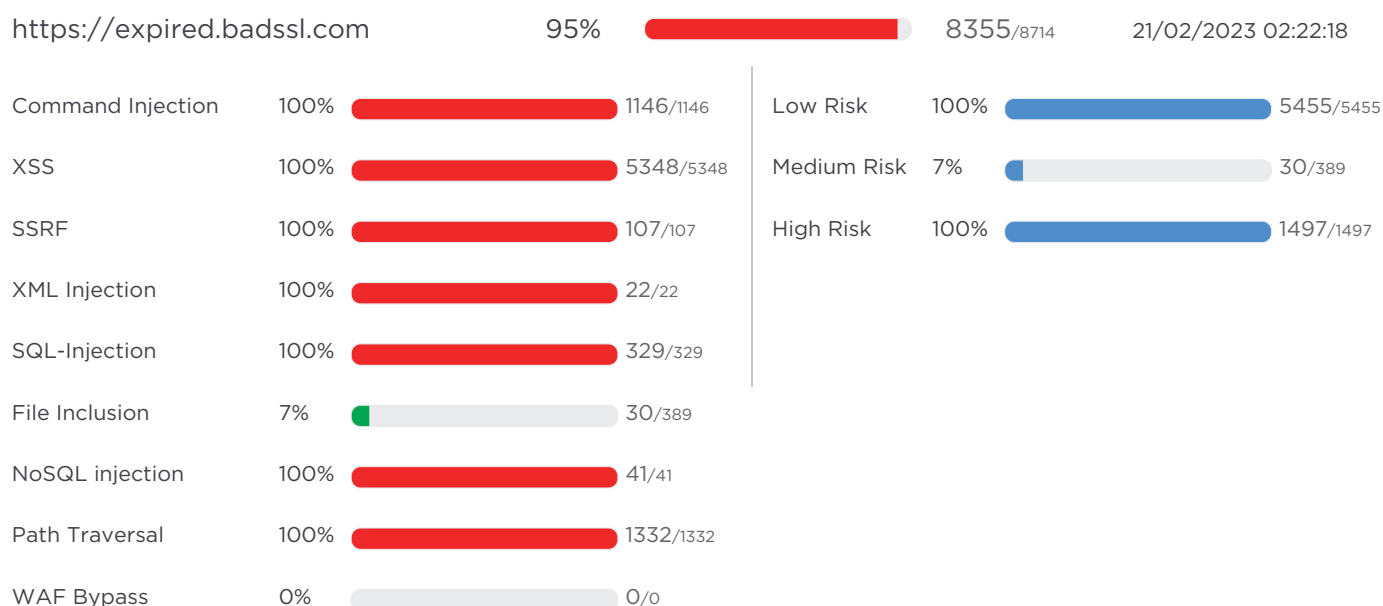
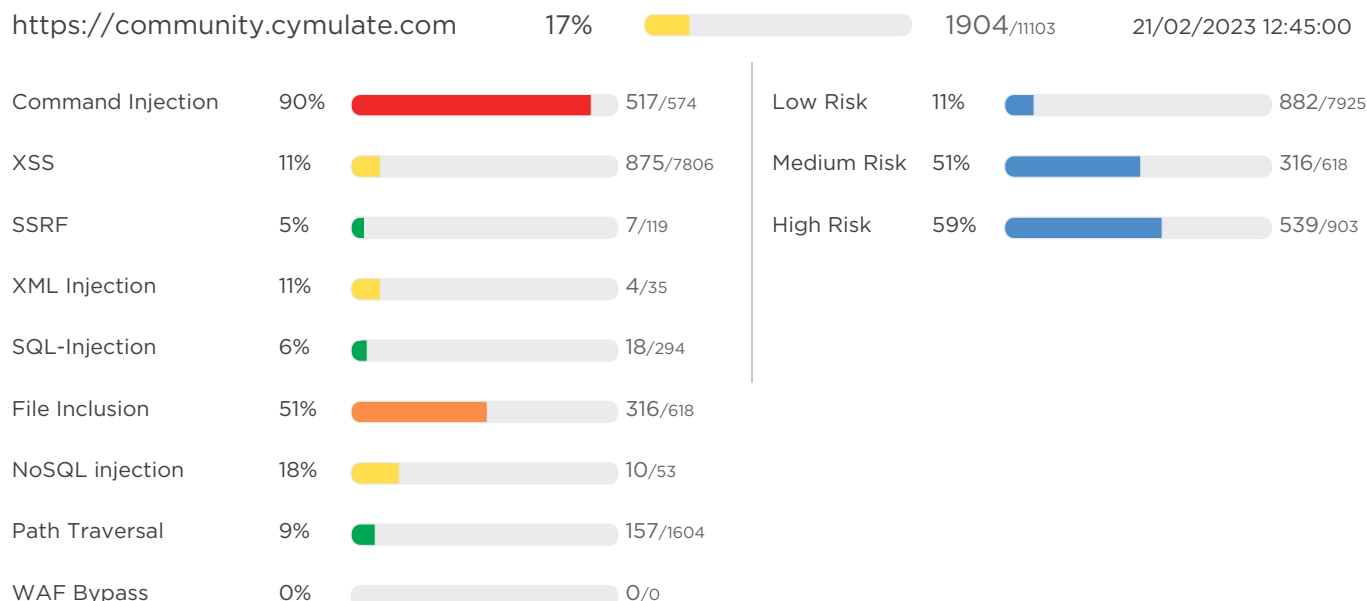
1

Dedicated signature based prevention according to the relevant attack.

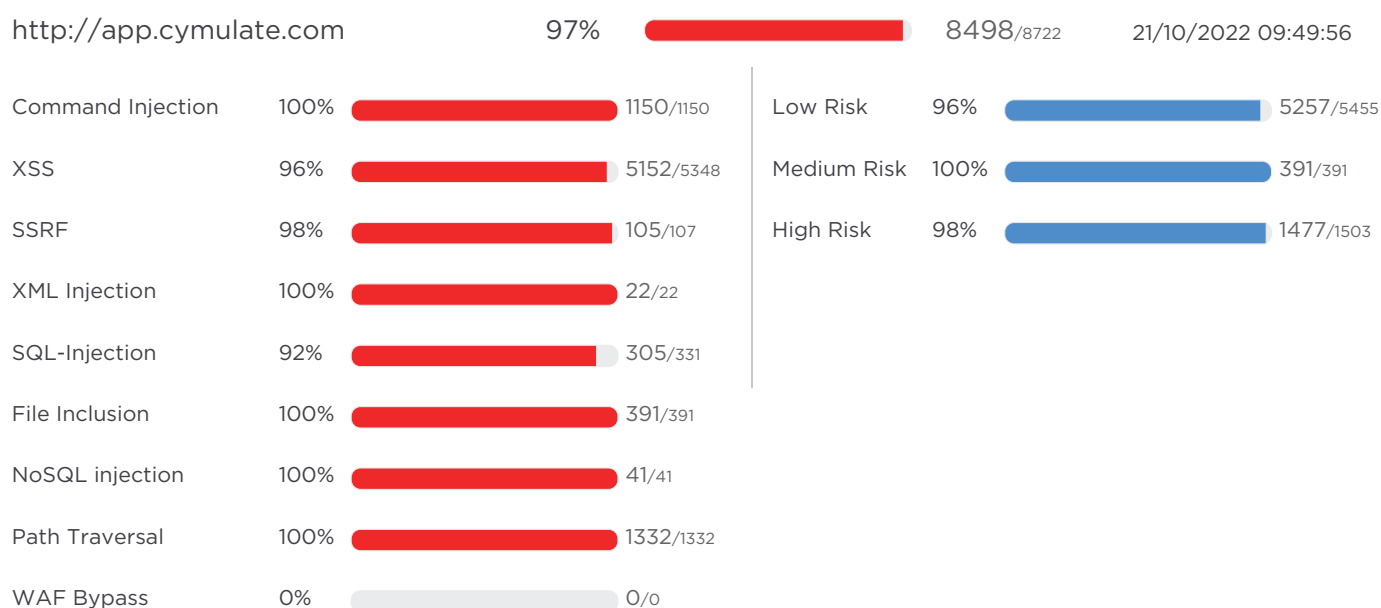
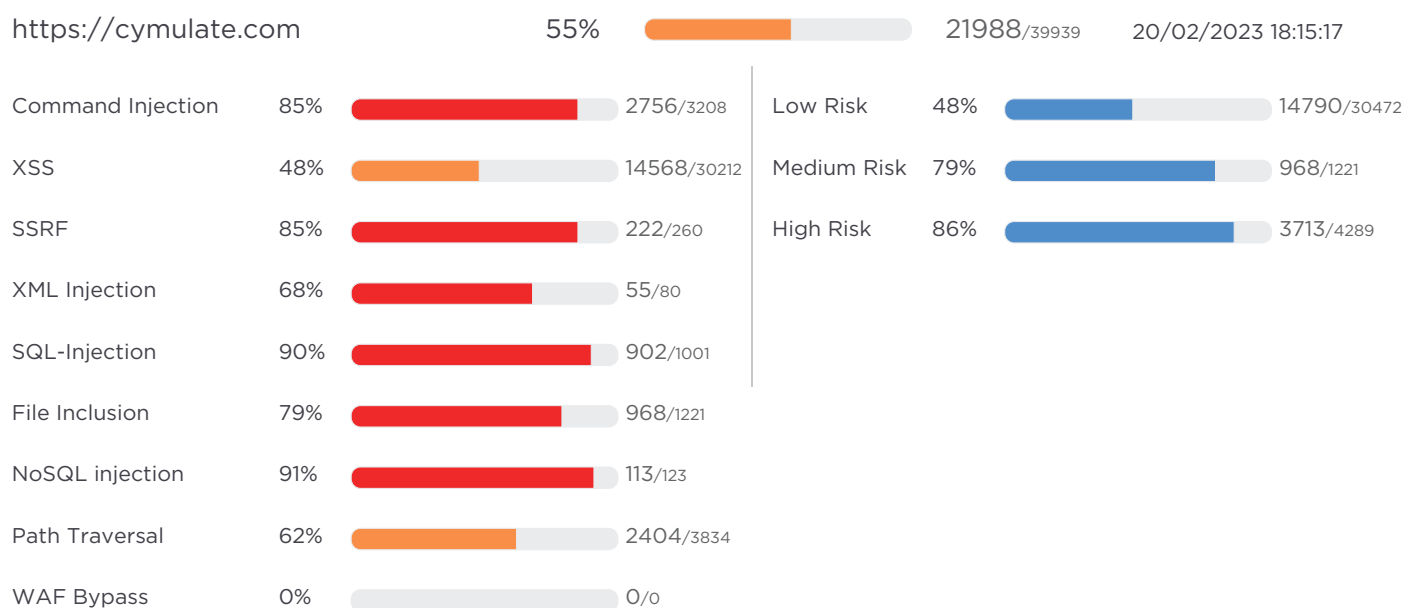
2

Creating regular expression based filters to block known malicious requests.

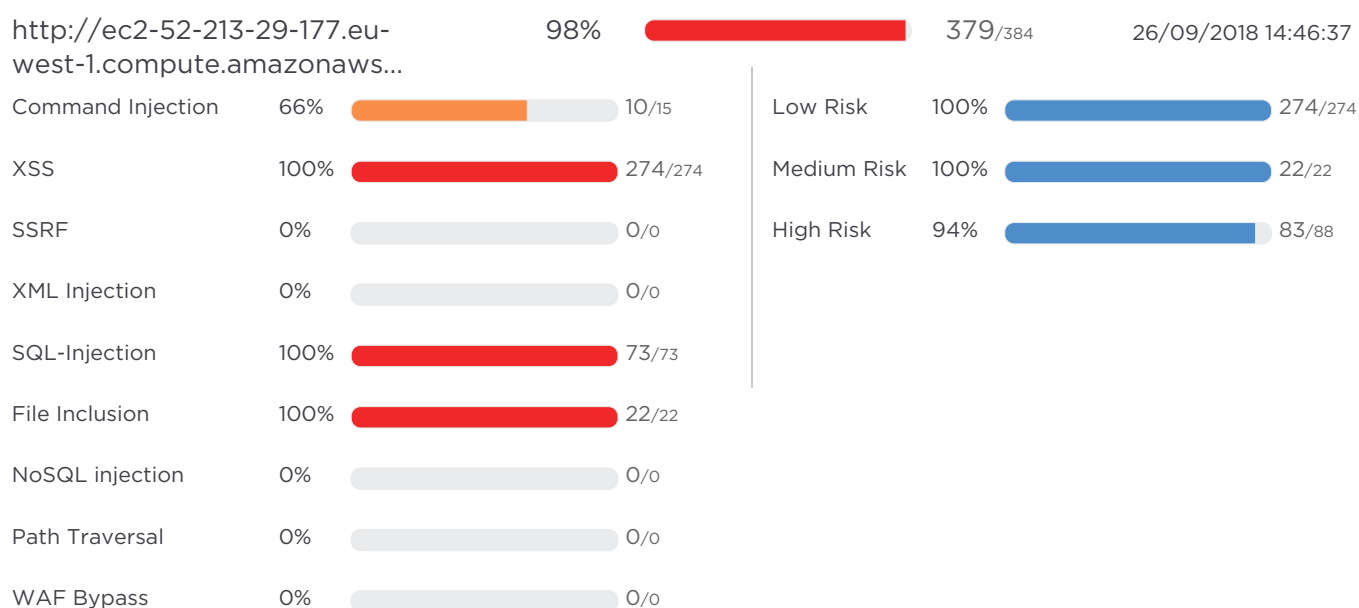
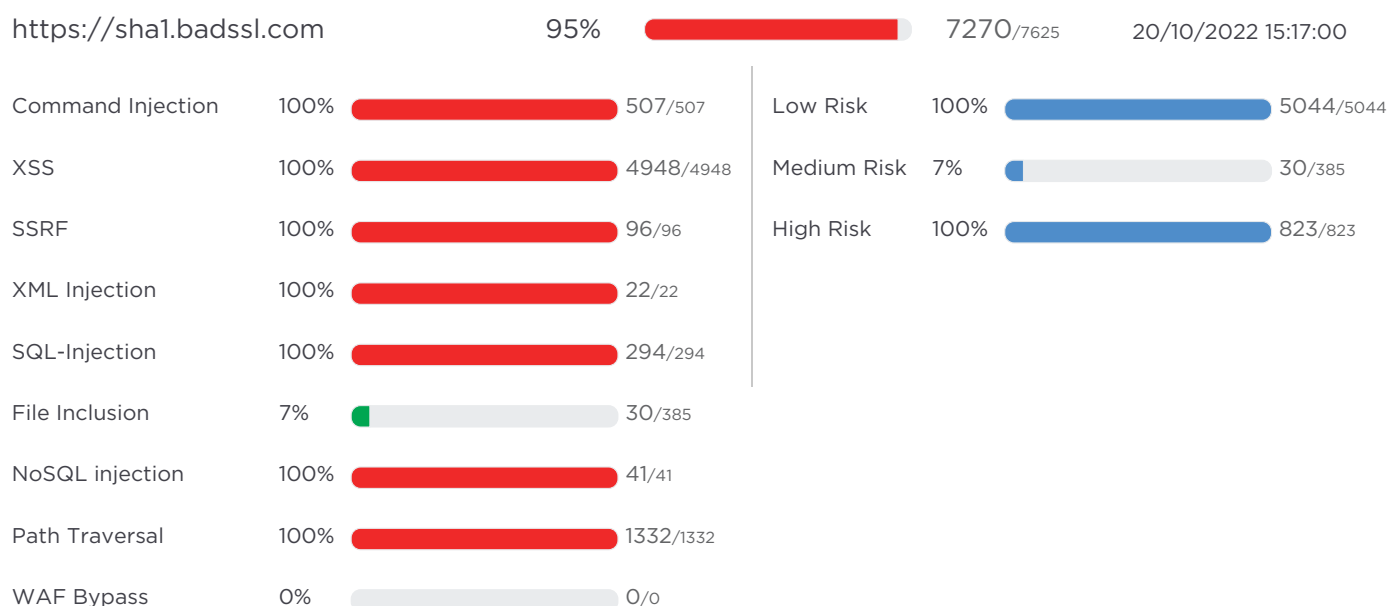
Web Application Site Summary



Web Application Site Summary



Web Application Site Summary



Appendix A

Attack Types

SQL-Injection

SQL injection is a code injection technique, used to attack data-driven applications, in which malicious SQL statements are inserted into an entry field for execution. It can be used to spoof identity, tamper with existing data, cause repudiation issues such as changing balances, allow the complete disclosure of all data on the system, destroy the data or make it otherwise unavailable, and become administrators of the database server.

Cymulate will send crafted payloads that can lead to potential SQL code injections. Payloads are sent in a controlled and safe manner and won't affect tested site.

[Reference](#)

XSS

Cross-site scripting (XSS) is a type of computer security vulnerability typically found in web applications. XSS enables attackers to inject client-side scripts into web pages viewed by other users. A cross-site scripting vulnerability may be used by attackers to bypass access controls, hijack session cookies and more.

Cymulate will send crafted payloads that can potentially enable attackers to inject client-side scripts into web pages viewed by other users.

Payloads are sent in a controlled and safe manner and won't affect tested site.

[Reference](#)

File Inclusion

A file inclusion vulnerability is a type of web vulnerability that is most commonly found to affect web applications that rely on a scripting run time. This issue is caused when an application builds a path to executable code using an attacker-controlled variable in a way that allows the attacker to control which file is executed at run time.

Cymulate will send crafted file inclusion payloads that can potentially lead to remote code execution on the web server that runs the web application.

Payloads are sent in a controlled and safe manner and won't affect tested site.

[Reference](#)

Command Injection

Command injection is an attack in which the goal is execution of arbitrary commands on the host operating system via a vulnerable application. Command injection attacks are possible when an application passes unsafe user supplied data (forms, cookies, HTTP headers etc.) to a system shell. In this attack, the attacker-supplied operating system commands are usually executed with the privileges of the vulnerable application. Command injection attacks are possible largely due to insufficient input validation.

Cymulate will send crafted payloads that can lead to potential execution of arbitrary commands on the host operating system via a vulnerable application.

Payloads are sent in a controlled and safe manner and won't affect tested site.

[Reference](#)

XML Injection

XML injection manipulates or compromises the logic of an XML application or service. The injection of unintended XML content and/or structures into an XML message can alter the intended logic of an application, and XML Injection can cause the insertion of malicious content into resulting messages/documents.

With a successful XML Injection attack, the attacker can steal the entire database, or can even log in as the administrator of the website. Other security issues such as XSS and DOS attack can be leveraged with malicious XML Injections.

SSRF

Server-side request forgery (also known as SSRF) is a web security vulnerability that allows an attacker to induce the server-side application to make HTTP requests to an arbitrary domain of the attacker's choosing.

[Reference](#)

Path Traversal

A path traversal attack allows attackers to access directories that they should not be accessing, like config files or any other files or directories that may contain server data not intended for the public.

[Reference](#)

WAF Bypass

WAF Bypass refers to a sophisticated set of techniques designed to circumvent or evade the detection mechanisms implemented by Web Application Firewalls.

These security systems are crucial for safeguarding web applications by monitoring, filtering, and potentially blocking incoming web traffic based on predefined rulesets.

However, determined attackers continuously develop novel methods to bypass these defenses, exploiting vulnerabilities or employing obfuscation techniques to disguise malicious payloads.

The goal of WAF bypass is to subvert the protective measures of the WAF, enabling malicious actors to successfully launch attacks against web applications without triggering alerts or being blocked.

This can involve various strategies, such as encoding or encrypting malicious payloads, fragmenting requests, manipulating HTTP headers, or leveraging evasion tactics that exploit the intricacies of WAF rule processing.

[Reference](#)

Appendix B

The Cymulate Score

How is it Calculated?

The Cymulate platform is intended to provide your organization with a quantifiable risk score in order to understand your cyber security risk posture at any time based on the security solutions and capabilities at your disposal.

The following risk rating methods, models, assessments, and methodologies are used for calculating Cymulate assessments risk score:

NIST risk assessment (Special Publication 800-30)

- Threat Likelihood
- Impact

CVSS v3

- Confidentiality
- Integrity
- Availability
- Attack Vector
- Attack complexity
- Privileges Required
- User Interaction
- Remediation Level

DREAD

- Damage
- Reproducibility
- Exploitability
- Affected users
- Discoverability

The algorithm calculates the above factors, also takes into consideration MITRE's ATT&CK framework knowledge base of cyber adversary behavior and taxonomy for adversarial actions across their lifecycle. The result is a number score describing the total exposure level:

Minimal Risk
0-10

Low Risk
11-33

Medium Risk
34-67

High Risk
68-100

***The lower your score, the lower your cyber security risk.**